

OT ATTACKS AND COUNTERMEASURES

OT Concepts

OT Concepts

OT or Operational Technology is a combination of software and hardware designed to detect or cause changes in industrial operations through direct monitoring and/or controlling of industrial physical devices.

These devices include switches, pumps, lights, sensors, surveillance cameras, elevators, robots, valves, and cooling and heating systems. Any system that analyzes and processes operational data (such as technical components, electronics, telecommunications, and computer systems) can be a part of OT.

OT systems employ different approaches to design hardware and protocols that are unfamiliar to IT. Supporting older versions of software and hardware makes OT systems more vulnerable to cyber-attacks, as developing fixes or patches for them is very difficult.

Terminologies

Here are some of the most important and extensively used terms related to OT systems:

- **Assets:** Different components of OT are generally referred to as assets. Most OT systems, such as ICSs, comprise physical assets such as sensors and actuators, servers, workstations, network devices, and logical assets that represent the workings and containment of physical assets, such as graphics representing process flow, program logic, firmware, or firewall rules.
- **Zones and Conduits:** A network segregation technique used to isolate networks and assets to impose and maintain strong access control mechanisms.
- **Industrial Network and Business Network:** OT generally comprises a collection of automated control systems. These systems are networked to achieve a business objective. A network comprising these systems is known as an industrial network. An enterprise or business network comprises a network of systems that offer an information infrastructure to the business. Businesses often need to establish communications between business networks and industrial networks.
- **Industrial Protocols:** Most OT systems employ proprietary protocols or non-proprietary protocols. These protocols are generally used for serial communication and can also be used for communication over standard Ethernet using Internet Protocol (IP), along with transport layer protocols TCP or UDP.
- **Network Perimeter/Electronic Security Perimeter:** The network perimeter is the outermost boundary of a network zone, i.e., a closed group of assets. It acts as a point of separation between the interior and exterior of a zone. Generally, cybersecurity controls are implemented at the network perimeter.
An Electronic Security Perimeter refers to a boundary between secure and insecure zones.
- **Critical Infrastructure:** A collection of physical or logical systems and assets, the failure or destruction of which will severely impact security, safety, the economy, or public health.

The Purdue Model

Derived from the Purdue Enterprise Reference Architecture (PERA) model, which is a widely used conceptual model that describes the internal connections and dependencies of important components in ICS networks. It is also known as the *Industrial Automation and Control System reference model*.

The Purdue model consists of three (3) zones: the manufacturing zone (OT) and enterprise zone (IT), separated by a demilitarized zone (DMZ), which is used to restrict direct communication between the OT and IT systems. These zones are further divided into several operational levels.

Enterprise Zone (IT Systems)

The enterprise security zone is a part of IT, in which supply-chain management and scheduling are performed using business systems such as SAP and ERP. It consists of two (2) levels:

- **Level 5 (Enterprise Network):** This is a corporate-level network where business operations such as B2B (business-to-business) and B2C (business-to-customer) services are performed. Internet connectivity and management can be handled at this level.
- **Level 4 (Business Logistics Systems):** All the IT systems supporting the production process in the plant lie at this level. Managing schedules, planning, and other logistics of the manufacturing operations is performed here.

Manufacturing Zone (OT Systems)

All the devices, networks, control, and monitoring systems reside in this zone. The manufacturing zone consists of four (4) levels:

- **Level 3 (Operational Systems/Site Operations):** In this level, production management, individual plant monitoring, and control functions are defined. Production workflows and output of the desired product are ensured at this level.
- **Level 2 (Control Systems/Area Supervisory Controls):** Supervising, monitoring, and controlling the physical process is carried out at this level.
- **Level 1 (Basic Controls/Intelligent Devices):** Analysis and alteration of the physical process can be done at this level. The operations in basic control include “start motors,” “open valves,” “move actuators,” etc.
- **Level 0 (Physical Process):** In this level, the actual physical process is defined, and the product is manufactured. Higher levels control and monitor operations at this level; therefore, this layer is also referred to as Equipment Under Control (EUC). A minor error in any of the devices at this level can affect overall operations.

Industrial Demilitarized Zone (IDMZ)

The demilitarized zone is a barrier between the manufacturing zone (OT systems) and the enterprise zone (IT systems) that enables a secure network connection between the two systems. The zone is created to inspect the overall architecture. If any errors or intrusions compromise the working systems, the IDMZ holds the error and allows production to continue without interruption.

OT Attacks

OT Attacks

Most OT systems use legacy or outdated software with no security in place, leaving a potential for cybercriminals to gain access to corporate IT networks and infrastructure.

Types of OT Threats

Maintenance and Administrative Threat

Attackers exploit zero-day vulnerabilities to target the maintenance and administration of the OT network. By exploiting these vulnerabilities, attackers inject and spread malware to IT systems and target connected industrial control systems such as SCADA and PLC.

Data Leakage

Attackers may exploit IT systems connected to the OT network to gain access to the IT/OT gateway and steal operationally significant data such as configuration files.

Protocol Abuse

Owing to compatibility issues, many OT systems use outdated legacy protocols and interfaces such as Modbus and CAN bus. Attackers exploit these protocols and interfaces to perform various attacks on OT systems. For example, attackers may abuse the emergency stop (e-stop), which is a safety mechanism used to shut down the machinery in emergencies to execute single-packet attacks.

Potential Destruction of ICS Resources

Attackers exploit vulnerabilities in OT systems to disrupt or degrade the functionality of the OT infrastructure, leading to life- and safety-critical issues.

Reconnaissance Attacks

OT systems allow remote communication with minimal or no encryption or authentication mechanisms. Attackers can perform initial reconnaissance and scanning on the target OT infrastructure to gather information necessary for later stages of the attack.

Denial-of-Service Attacks

Attackers exploit communication protocols such as Common Industrial Protocol (CIP) to perform DoS attacks on the target OT systems. For example, an attacker may send a malicious CIP connection request to a target device; once a connection is established, he/she may send a fake IP configuration to the device. If the device accepts the configuration, loss of communication may occur between the device and other connected systems.

HMI-Based Attacks

Human–Machine Interfaces (HMIs) are often called Hacker–Machine Interfaces. Even with the advancement and automation of OT, human interaction and control over the operational process remain challenges due to underlying vulnerabilities.

The lack of global standards for developing HMI software without any defense-in-depth security measures leads to many security problems. Attackers exploit these vulnerabilities to perform various attacks, such as memory corruption, code injection, and privilege escalation etc., on target OT systems.

Exploiting Enterprise-Specific Systems and Tools

Attackers may target ICS devices such as Safety Instrumented Systems (SIS) to inject malware by exploiting underlying protocols to detect hardware and systems used in communications, and further disrupt or damage their services.

Spear Phishing

Attackers send fake emails containing malicious links or attachments, seemingly originating from legitimate or well-known sources, to the victim. When the victim clicks on the link or downloads the attachment, it injects malware, starts damaging resources, and spreads itself to other systems.

For example, an attacker sends a fraudulent email with a malicious attachment to a victim's system that maintains the sales software of the operational plant. When the victim downloads the attachment, the malware is injected into the sales software, propagates itself to other networked systems, and finally damages industrial automation components.

Malware Attacks

Attackers are reusing legacy malware packages that were previously used to exploit IT systems to exploit OT systems. They perform reconnaissance attacks to identify vulnerabilities in newly connected OT systems. Once they detect vulnerabilities, they reuse the older malware versions to perform various attacks on the OT systems. In some scenarios, attackers also develop malware targeting OT systems, such as ICS/SCADA.

Exploiting Unpatched Vulnerabilities

Attackers exploit unpatched vulnerabilities in ICS products, firmware, and other software used in OT networks. ICS vendors develop products that are reliable and provide high-speed, real-time performance with no built-in security features.

In addition, these vendors cannot develop patches for the identified vulnerabilities at the same speed as IT vendors. For these reasons, attackers target and exploit ICS vulnerabilities to perform various attacks on OT networks.

Side-Channel Attacks

Attackers perform side-channel attacks to retrieve critical information from an OT system by observing its physical implementation. Attackers use various techniques, such as timing analysis and power analysis, to perform side-channel attacks.

Buffer Overflow Attack

The attacker exploits various buffer overflow vulnerabilities that exist in ICS software, such as HMI web interface, ICS web client, communications interfaces, etc., to inject malicious data and commands to modify the normal behavior and operation of the systems.

Exploiting RF Remote Controllers

OT networks use RF technology to control various industrial operations remotely. RF communication protocols lack built-in security for remote communication. Vulnerabilities in these protocols can be exploited by attackers to perform various attacks on industrial machines that lead to production sabotage, system control, and unauthorized access.

OT Attack Countermeasures

OT Attack Tools and Countermeasures

The **ICS Exploitation Framework (ISF)** is an exploitation framework based on Python that is similar to the Metasploit framework. This tool provides various exploit modules that allow attackers to hack target ICS systems and networks.

Follow the countermeasures discussed below to defend against OT hacking:

- Regularly conduct a risk assessment to reduce the current risk exposure
- Use purpose-built sensors to discover the vulnerabilities in the network inactively
- Incorporate threat intelligence to uncover threats and protect assets by prioritizing OT patches
- Regularly upgrade OT hardware and software tools
- Disable unused ports and services
- Update systems to the latest technologies and patch systems regularly
- Implement secure configuration and secure coding practices for OT applications
- Maintain an asset register to track the information and to scrutinize outdated and unsupported systems
- Perform continuous monitoring and detection of the log data generated by the OT systems for detecting real-time attacks
- Train employees on the latest security policies and raise awareness of the latest threats and risks
- Use strong and secure passwords using hashing, and change the default factory-set passwords
- Secure remote access through multiple layers of defense by implementing two-factor authentication, VPNs, encryption, firewalls, etc.
- Implement incident response and business continuity plans
- Secure the network perimeter to filter and prevent unauthorized inbound traffic
- Regularly scan systems and networks using anti-malware tools
- Restrict network traffic by using techniques like rate-limiting and whitelisting to prevent DoS and brute-forcing attacks
- Harden the systems by disabling unused services and functionalities
- Use only tested and familiar third-party web servers for serving the ICS web applications
- Ensure ICS vendors add cryptographic signatures to application updates
- Perform periodic audits of industrial systems to validate the security controls, production, and management systems

Reference:

EC-Council. (2021). *Ethical hacking essentials* (1st ed.). EC-Council.